

Monitorización de eventos de seguridad

Ciberinteligencia y Herramientas de Análisis



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

René Serral <rene.serral@upc.edu>

Módulo 5: Correlación de Logs

- Introducción
- OSSIM
- Splunk

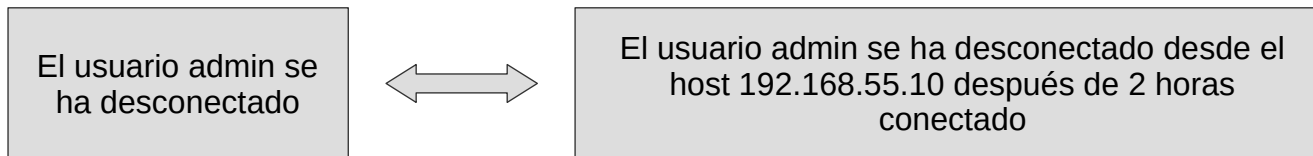


Todos los créditos por estas slides van a:
Manel Rodero



Introducción

- Los registros varían mucho de un sistema a otro
- Casi no existen normas que indiquen qué se registra y con qué nivel de detalle
- Diversidad en qué se reporta, desde descripción de un problema a códigos internos de error
- Casi siempre un evento se indica como una entrada puntual en un log, sin contexto



Que es la correlación de logs?

- Es la búsqueda de patrones o relación entre eventos que no son visibles usando los registros de forma aislada
- La búsqueda se realiza mediante reglas que reciben los patrones de análisis con el uso de operadores lógicos

"**IF** a new user **IS** created on the domain **AND** a new change control ticket **IS NOT** created in the change control database"

Porque es necesario?

La gestión de eventos está compuesta por muchos pasos complicados

- Determinar riesgos
- Bloquear o poner en cuarentena
- Detectar un problema, anomalía o patrón
- Registrar
- Alertar
- Analizar
- Integridad de datos
- Corregir o recuperar
- Informes
- etc.



Objetivos de la correlación: Conocimiento

- Determinar, en “tiempo real”, la probabilidad de materialización de una amenaza en un momento dado
- Conocer, en “tiempo real”, cuando comienza un ataque al sistema permitiendo una alerta temprana
- Conocer si un ataque ha tenido éxito o no y determinar el impacto real del mismo sobre un sistema
- Determinar los patrones de materialización de las amenazas, que serán utilizados posteriormente para implementar nuevas medidas de seguridad o mejorar las existentes

Alienvault OSSIM



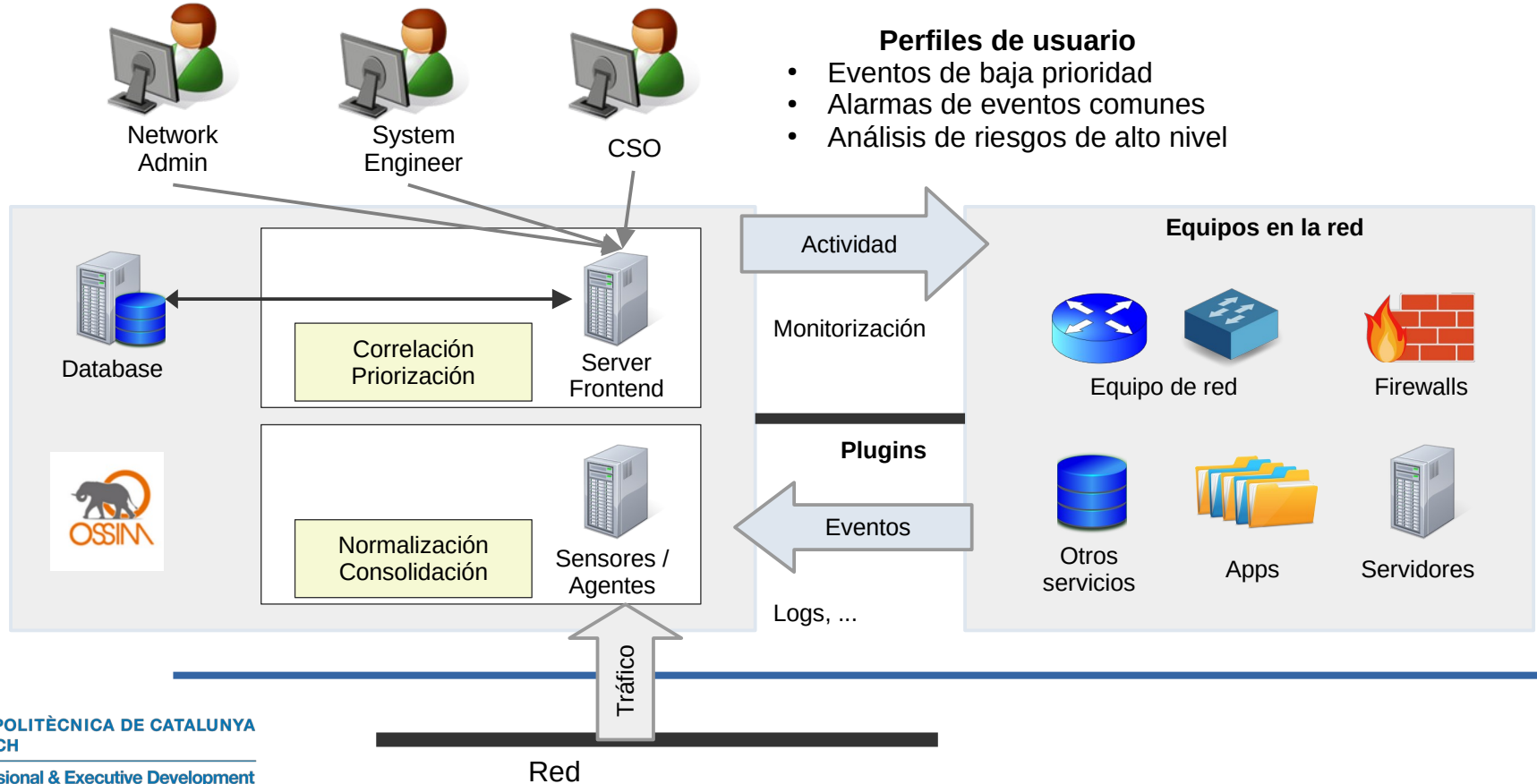
UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Que es OSSIM?

- OSSIM es una herramienta SIEM de código abierto creada por la empresa AlienVault (ahora AT& Cybersecurity) que permite:
 - **Recopilación** de eventos de fuentes diversas: servidores, aplicaciones, etc.
 - **Normalización** de los mismos = extracción de atributos en campos comunes
 - **Correlación** de los eventos para identificar patrones y relaciones entre ellos
- Proporciona inteligencia de seguridad:
 - Descarta falsos positivos
 - Evalúa el impacto de un ataque
- **Unifica** la gestión de la seguridad:
 - Centraliza la información
 - Integra herramientas de detección de amenazas

Arquitectura



Herramientas integradas

Capacidad	Herramienta	Descripción
Descubrimiento de activos	prads nmap OCS Inventory NG	Identificación de SO y aplicaciones Identificación de máquinas, SO y servicios Enumeración de paquetes instalados
Detección de amenazas	OSSEC Snort Suricata Kismet	Integridad de ficheros, detección de rootkits Detección de actividades maliciosas Procesado avanzado de flujos HTTP Detección de intrusión en redes inalámbricas
Monitorización del comportamiento	fprobe Nfdump/NFSen ntop tcpdump Nagios	Generación de flujos de datos de red Análisis de flujos de red Estadísticas de red y detección de protocolos Análisis de protocolos y captura de paquetes Monitorización de SO y servicios
Evaluación de vulnerabilidades	OpenVAS Nikto	Análisis de vulnerabilidades Escáner de vulnerabilidades web

Plugins (Conectores)

- Recolección de información
 - 4.15.1 (195 conectores)
 - 5.3.2 (280 conectores)
 - 5.6.0 (470 conectores)
 - 5.7.4 (522 conectores)
- `/usr/share/alienvault-plugins/d_clean/plugins`



Inteligencia

- Recolección de datos
 - Identificar, importar e integrar datos de eventos mediante las herramientas integradas y de terceros
- Normalización
 - Analizar, normalizar e integrar datos de eventos en un motor de análisis SIEM mediante conectores integrados
- Correlación cruzada
 - Aplicar directivas de correlación a los activos, vulnerabilidades, tráfico de red y datos de amenazas
- Alarmas y respuestas
 - Alarmas priorizadas con información detallada sobre la amenaza e instrucciones de remediación



Registros, Eventos, y SIDs

- Los dispositivos generan muchos mensajes diferentes en sus **registros**
- Estos registros se pueden expresar en nuestro lenguaje

New Session A3D113 Initiated
src:192.168.20.2 Authtype:2 ID:
admin with fwd option

"El usuario 'admin' inició la
sesión en <el sistema de donde
proviene este registro> desde el
host remoto 192.168.20.2"

- Cuando registro es un evento significativo se le puede asignar un **Security ID** (p.ej. User Logged In)
- Al buscar en los registros, se puede buscar por SID en lugar de por un texto específico

Normalización, tablas y campos

- La normalización de logs consiste, básicamente, en dividir un mensaje de registro en campos comunes que luego serán almacenados en una base de datos para poder ser consultados
- Registro:
 - Successful Login from 192.168.100.2 to account "Admin"
- Normalización:
 - Evento: Successful Login
 - Dirección origen: 192.168.100.2
 - Usuario: Admin

Cálculo del riesgo en OSSIM

- El riesgo es un valor entre 0 y 100, donde 100 es riesgo crítico y 0 sin riesgo
- Se calcula:
 - $\text{Riesgo} = \text{Valor activo} * (\text{Fiabilidad} * \text{Prioridad}/25)$
- **Fiabilidad:** probabilidad de falso positivo
 - Cuanto más selectivos los datos más fiabilidad
 - Ejemplo: Alarma de ataque por fuerza bruta:
 - **Directiva nivel 1:** 1 inicio de sesión fallido: Fiabilidad 1
 - **Directiva nivel 2:** 3 inicios de sesión fallidos en 300 segundos desde la misma dirección IP: Fiabilidad 2
 - **Directiva nivel 3:** 100 inicios de sesión fallidos en 3600 segundos desde la misma dirección IP: Fiabilidad 5
 - **Directiva nivel 4:** un inicio de sesión correcto desde la misma dirección IP que la denivel 3: Fiabilidad 10

Cálculo del riesgo en OSSIM

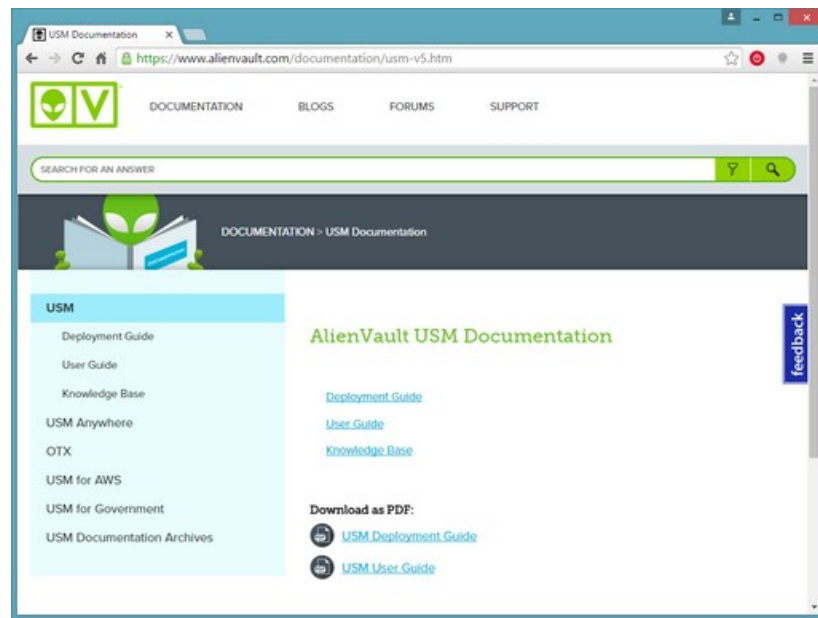
- El riesgo es un valor entre 0 y 100, donde 100 es riesgo crítico y 0 sin riesgo
- Se calcula:
 - $\text{Riesgo} = \text{Valor activo} * (\text{Fiabilidad} * \text{Prioridad}/25)$
- La **prioridad** indica con qué urgencia se tiene que investigar un evento
 - Por ejemplo, los inicios de sesión correctos o incorrectos es probable que llamen la atención tanto o más que los intentos de suplantación de identidad
 - Ahora bien, tienen una prioridad baja si se compara con la detección de una brecha de seguridad
 - Es decir, dados dos eventos que suceden al mismo tiempo, se necesita una manera de determinar el que tiene el mayor potencial de daño
 - Para hacerlo, se asignan valores de 0 a 5, siendo 5 el valor con una prioridad más alta

Cálculo del riesgo en OSSIM

- El riesgo es un valor entre 0 y 100, donde 100 es riesgo crítico y 0 sin riesgo
- Se calcula:
 - $\text{Riesgo} = \text{Valor activo} * (\text{Fiabilidad} * \text{Prioridad}/25)$
- El **valor del activo** se establece en una escala de 0 a 5, siendo 5 el que tiene un valor más alto, calculado en función de dos factores:
 - Ejemplo de posible escala de valores:
 - 5: cualquier servidor/dispositivo que pueda recibir conexiones de Internet o tenga acceso sin encriptar a datos valiosos (bancarios, sanidad, etc.). Controlador de dominio, servidor LDAP o cualquier otro servidor de autenticación. Servidor VPN
 - 4: cualquier servidor de bases de datos que no esté en el conjunto anterior. Servidor de aplicaciones. Repositorio de código
 - 3: cualquier otro dispositivo o servidor en producción
 - 2: dispositivos o servidores "no producción" (pruebas)
 - 1: cualquier servidor o dispositivo que no preocupan para nada

Información del producto¹

- Instalación del producto
- Integración con diferentes dispositivos
- Guías de usuario
- Vídeos de aprendizaje



¹ <https://www.alienvault.com/documentation/>

Resource Center¹

- Webcasts
- Infografías
- Vídeos
 - Bash and Shellshock
 - Detect Heartbleed
 - ...



¹ <https://www.alienvault.com/resource-center/>

Probando OSSIM



- Desplegando la máquina
- Descubrimiento de activos y análisis de vulnerabilidades
- Syslog y OSSEC HIDS
- Eventos SIEM

Splunk



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development



Que es Splunk?

- Splunk es un "motor de búsqueda para **datos de las máquinas**"
 - Es decir, los generados por las aplicaciones, los servidores, los dispositivos de red, etc.
 - Estos datos son más que registros o eventos:
 - Datos de configuración, datos de las API y colas de mensajes, resultados de comandos de diagnóstico, etc.
- ¿Qué lo diferencia de un gestor de logs tradicional?
 - Permite realizar búsquedas y análisis de la información en **tiempo real** de forma ágil y sencilla
 - Permite identificar patrones, proporcionar métricas, diagnosticar problemas y, en general, proporcionar capacidad de decisión
 - Es decir, genera **inteligencia operativa**



Inteligencia Operativa

- La inteligencia operativa permite comprender en tiempo real lo que está sucediendo en los sistemas TI y la infraestructura tecnológica para poder tomar decisiones informadas

- Servidores

- Origen del tráfico IP
- Amenazas de seguridad
- Vulnerabilidades de red
- Tráfico de red y picos

- Sistemas

- Rendimiento del sistema
- Uso de CPU y carga
- Logs de acceso de usuarios
- Monitorización del rendimiento



Problemas de la búsqueda en tiempo real

- Hay una cantidad enorme de logs por unidad de tiempo
- Como comprobar las amenazas de seguridad?
- Como analizar las métricas de la empresa...
- **Splunk** proporciona:



Reenvío de
registros en
tiempo real



Análisis de
syslog en
tiempo real



Monitorización
del servidor en
tiempo real



Alertas/
Notificaciones
en tiempo real



Datos históricos
/ almacén de
logs y análisis

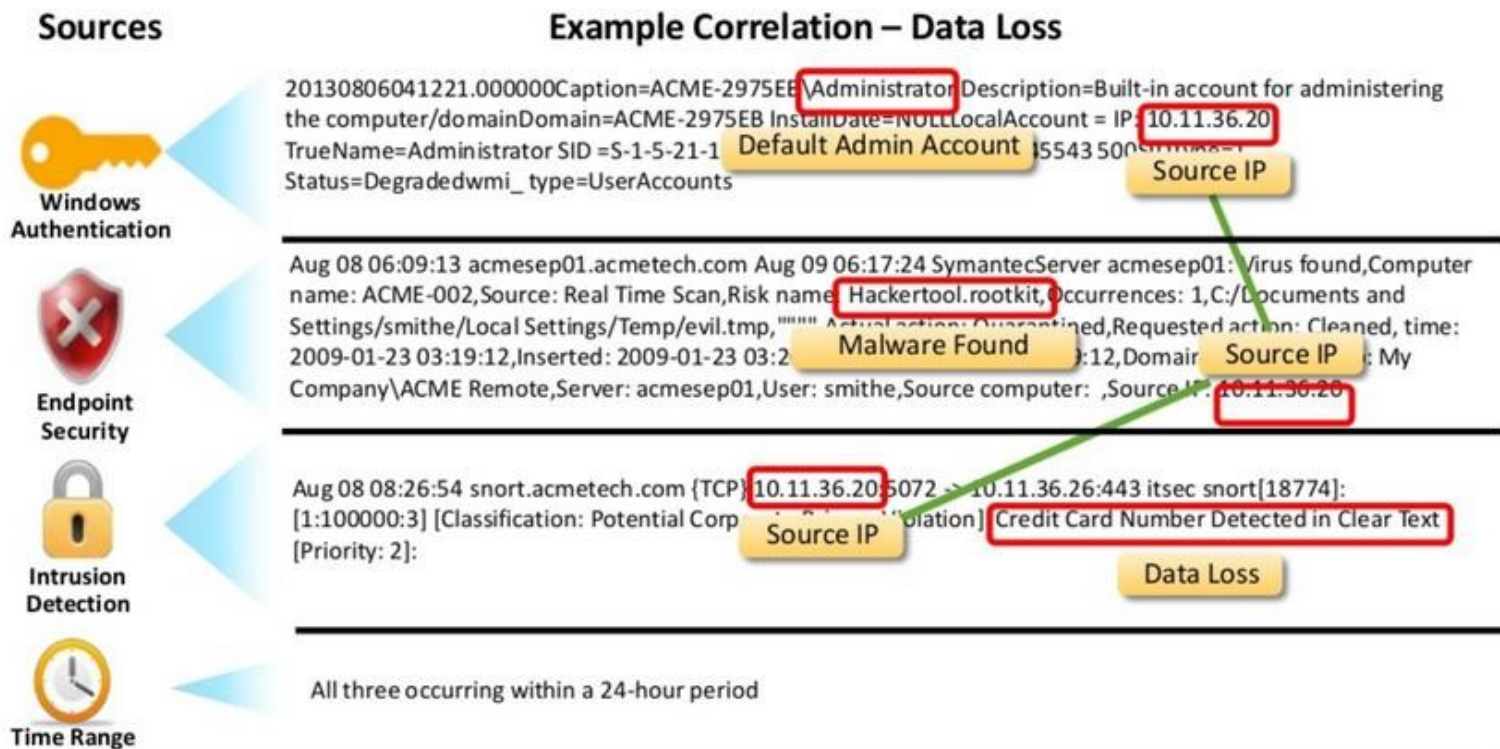
Qué Datos y de donde?

- Capaz de recopilar cualquier dato en tiempo real
- Desde cualquier origen o ubicación



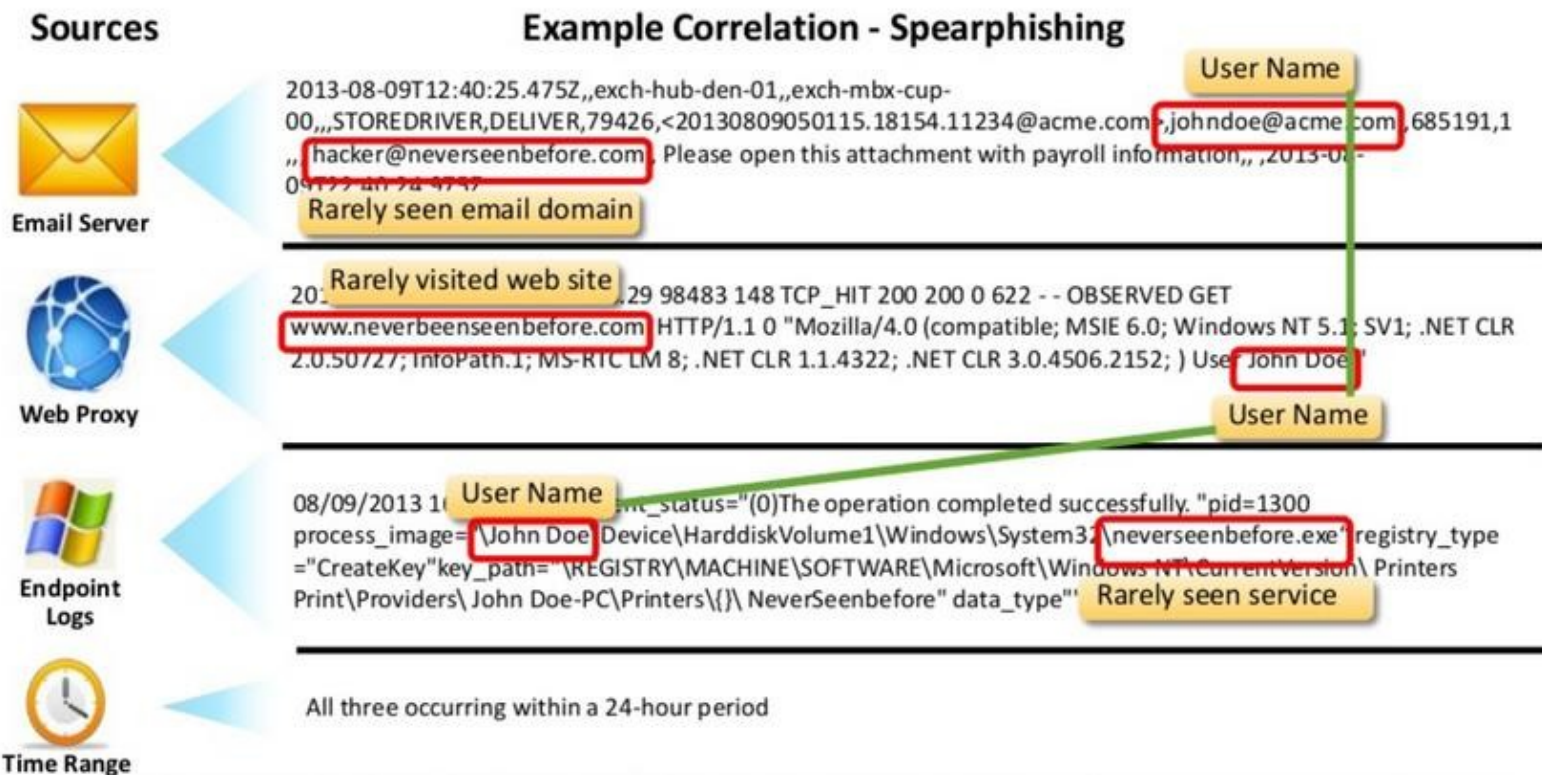
Correlación de eventos

- Ejemplo:** monitorización en tiempo real de amenazas conocidas



Correlación de eventos

- Ejemplo:** monitorización en tiempo real de amenazas conocidas



Correlación de eventos

- **Basadas en temas** → proximidad en el tiempo o localización geográfica
 - Por ejemplo, localizar los eventos que han sucedido desde el último segundo al último año
- **Basadas en transacciones** → seguimiento de una serie de eventos relacionados como una única transacción
 - Permite medir su duración o número de sucesos
- **Búsquedas secundarias** → usar el resultado de una búsqueda dentro de otra
 - P. ej. Ver un evento si se ha superado el umbral de otro
- **Búsquedas** → correlacionar datos con fuentes externas
- **Uniones** → Soporte para uniones SQL (inner y outer)
 - Por ejemplo, usando campos como usuario o ID de evento



Versiones de Splunk

- **Enterprise:** guardado de logs 60 días
- **Light:** guardado de logs 30 días
- **Cloud:** guardado de logs 15 días

Splunk Light

Software or Cloud Service

- ✓ Up to 5 users
- ✓ Ingest up to 20GB of data per day
- ✓ Collect and Index any data
- ✓ Real-time search, analysis, and visualization
- ✓ Monitor and alert

☁ Free Cloud Trial

📄 Free Download

Splunk Enterprise

Software

- ✓ Unlimited users
- ✓ Unlimited data
- ✓ Collect and Index any data
- ✓ Real-time search, analysis, and visualization
- ✓ Monitor and alert
- ✓ Mission-critical performance, scale, and reliability
- ✓ Splunk Premium Solutions and Apps from Splunkbase

📄 Free Download

Splunk Cloud

Cloud Service

- ✓ Unlimited users
- ✓ Unlimited data
- ✓ Collect and Index any data
- ✓ Real-time search, analysis, and visualization
- ✓ Monitor and alert
- ✓ Mission-critical performance, scale, and reliability — 100% uptime SLA
- ✓ Select Splunk Premium Solutions and Apps from Splunkbase

☁ Free Cloud Trial

Versiones de Splunk

Features	Splunk Free	Splunk Light	Splunk Enterprise	Splunk Cloud
Maximum Daily Indexing Volume	500MB	20GB	Unlimited	Unlimited
Maximum Users	1	5	Unlimited	Unlimited
Universal Data Collection/ Indexing	✓	✓	✓	✓
Metrics Store	✓	✓	✓	✓
Data Collection Add-Ons	✓	✓	✓	✓
Monitoring and Alerting		✓	✓	✓
Dashboards and Reports	✓	✓	✓	✓
Search and Analysis	✓	✓	✓	✓
Event Annotation	✓	✓	✓	✓
Automatic Data Enrichment	✓	✓	✓	✓

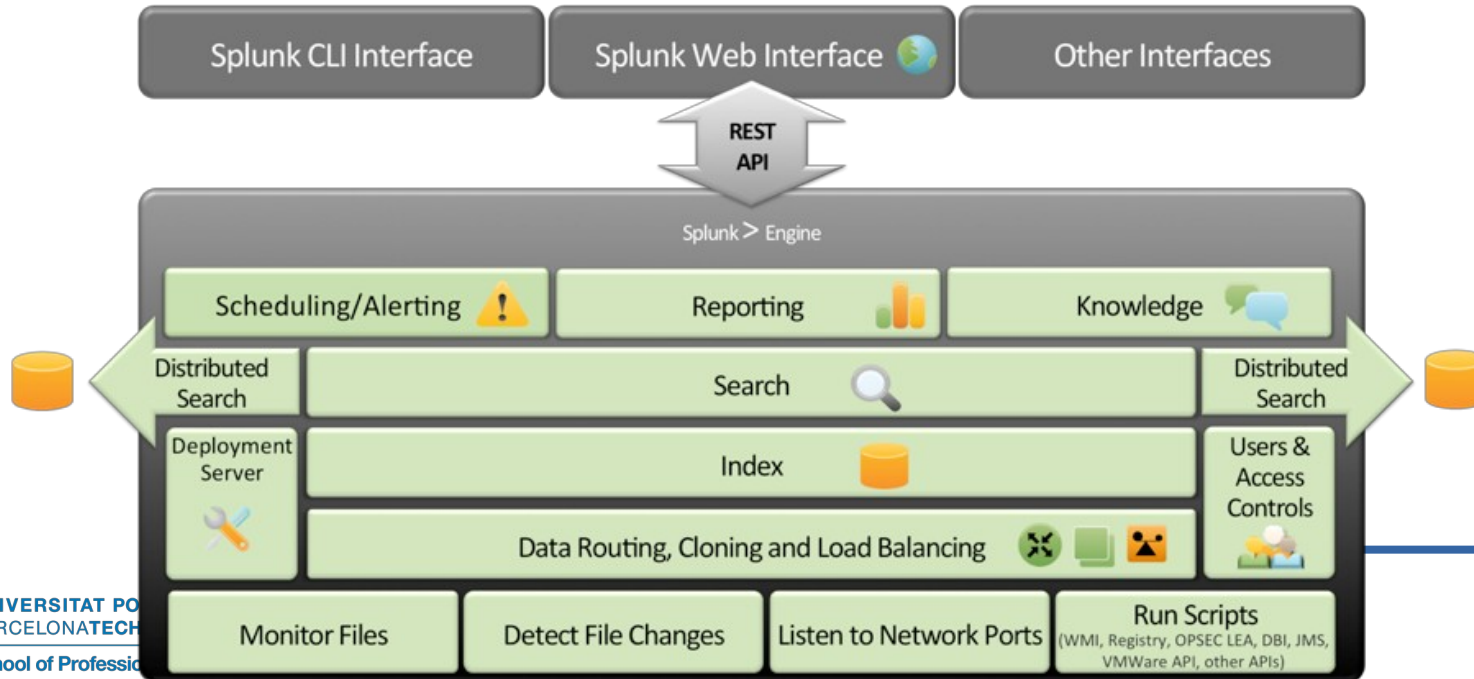


Versiones de Splunk

Features	Splunk Free	Splunk Light	Splunk Enterprise	Splunk Cloud
Anomaly Detection	✓	✓	✓	✓
Tables, Data Models and Pivot	✓		✓	✓
Splunkbase Apps	✓	App for AWS (only)	✓	✓
Splunk Premium Solutions			✓	✓
High Availability			✓	✓
Disaster Recovery			✓	✓
Clustering			✓	✓
Distributed Search			✓	✓
Performance Acceleration			✓	✓
Access Control		User and Admin only	Granular and Customizable	Granular and Customizable

Arquitectura

- Inherentemente distribuida permite buscar los datos independientemente de su ubicación

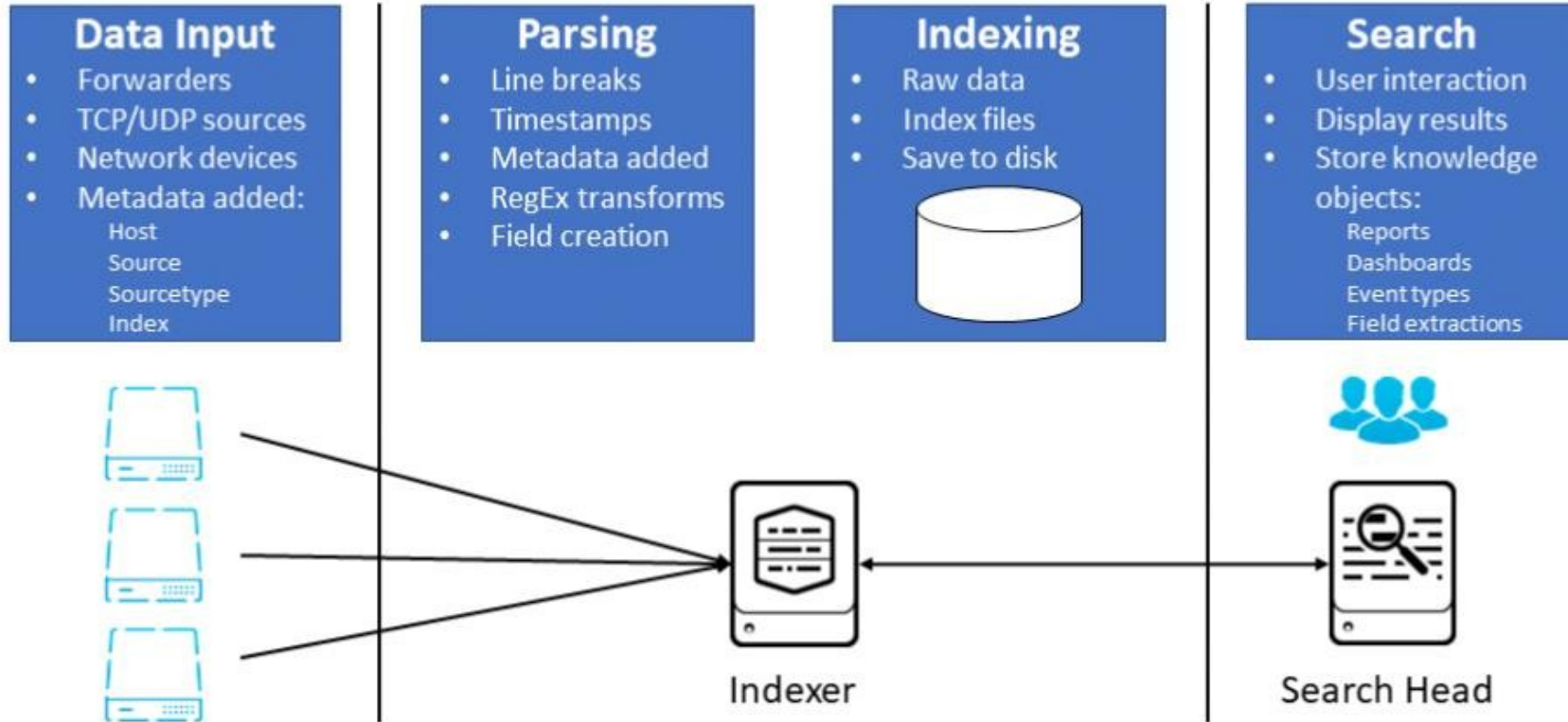


Etapas de procesamiento

- Entrada de datos
 - Se accede a todos los datos desde la fuente
 - Se convierten en bloques de 64k
- Las claves de los metadatos incluyen el nombre host, origen y tipo de datos
 - Almacenamiento de datos
 - Fase de análisis
 - Examen, análisis y transformación de los datos en eventos
- Fase de indexación
 - Se escriben los eventos analizados en la cola de indexación
 - Permite que los datos estén fácilmente disponibles para realizar búsquedas
- Búsqueda de datos
 - Se controla cómo se accede a los datos, cómo se usan y cómo se ven



Etapas de procesamiento



Splunk Forwarder

- Los reenviadores permiten recopilar todo tipo de datos locales:
 - Ficheros de log
 - Resultados de comandos y scripts
 - Cambios de configuración
 - ...
- Se pueden configurar para enviar los datos en tiempo real con muy poco uso de CPU
- Hay dos tipos:
 - Splunk Universal Forwarder
 - Splunk Heavy Forwarder



Splunk Indexer

- Indexa y almacena los datos que se envían desde los reenviadores
- Convierte los datos en eventos y los indexa para que las operaciones de búsqueda sean eficientes
 - Si los datos provienen del Universal Forwarder se analizan eliminando datos no deseados y después se indexan
 - Si los datos provienen del Heavy Indexer sólo se indexan
 - Los datos brutos RAW se comprimen
 - Se crean archivos de índice *.tsidx
- No es necesario preocuparse por la pérdida de datos porque Splunk mantiene varias copias de los datos indexados
 - Replicación de índice o agrupación de indexadores



Search Head

- Es la interfaz gráfica donde el usuario podrá realizar búsquedas utilizando palabras clave
- Lenguaje SPL
 - Se puede instalar en más de un servidor
- Tipos:
 - Search Head es la UI
 - Search Peer:
 - Resultados de cerca
 - Indexación

New Search Save As Close

buttercupgames (error OR fail* OR severe) All time

✓ 427 events (before 4/17/19 11:30:04.000 AM) No Event Sampling

Events (427) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect 1 day per column

Timeline of events

Display options List Format 20 Per Page

< Hide Fields All Fields

SELECTED FIELDS

- a host 3
- a source 3
- a sourcetype 1

INTERESTING FIELDS

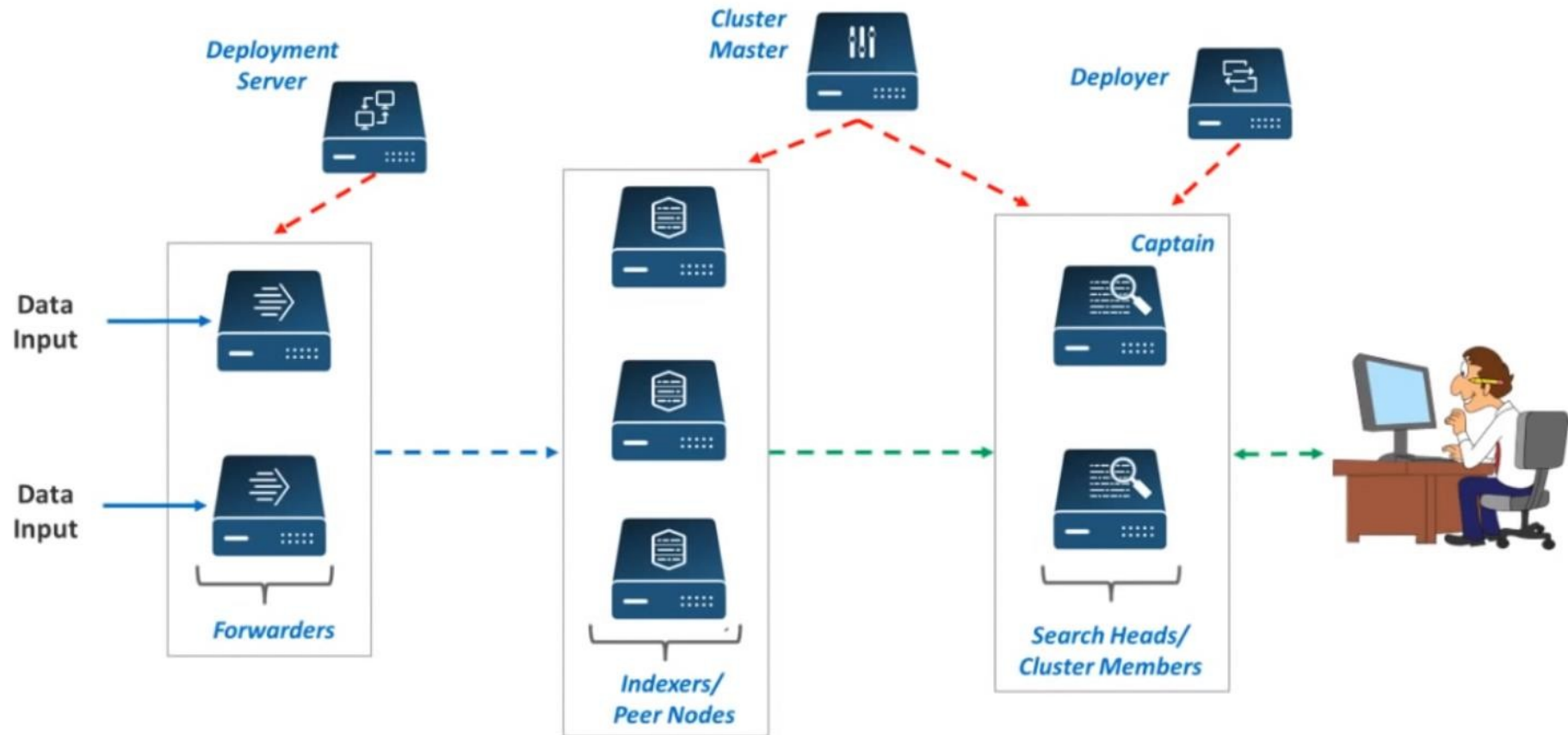
- a action 1
- # bytes 100+
- a clientip 100+
- # date_hour 24

Fields sidebar

Events viewer

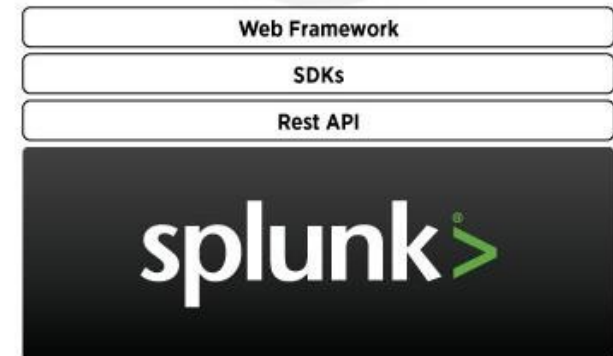
i	Time	Event
>	4/16/19 5:57:58.000 PM	12.130.60.5 - - [16/Apr/2019:17:57:58.000] "POST /cart/error.do?msg=CreditDoesNotMatch&JSESSIONID=SD5SL6FF7ADFF53001 HTTP 1.1" 200 420 "http://www.buttercupgames.com/cart.do?action=purchase&itemId=EST-19" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; WOW64; Trident/5.0; BOIE9;ENUS)" 232 host = www1 source = tutorialdata.zip:/www1/access.log sourcetype = access_combined_wcookie
>	4/16/19 5:53:57.000 PM	64.66.0.20 - - [16/Apr/2019:17:53:57] "POST /cart/error.do?msg=NothingInCart&JSESSIONID=SD6SL4FF1ADF52990 HTTP 1.1" 200 420 "http://www.buttercupgames.com/cart.do?action=purchase&itemId=EST-27" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_7_4) AppleWebKit/536.5 (KHTML, like Gecko) Chrome/19.0.1084.46 Safari/536.5" 521 host = www2 source = tutorialdata.zip:/www2/access.log sourcetype = access_combined_wcookie

Resumen de componentes



Plataforma de desarrollo

- Se pueden crear aplicaciones Splunk con paneles y visualización de datos personalizados
- **SDK** de Splunk Enterprise
 - Java, JavaScript, C# y Python
- SDK de Splunk Cloud Service
 - JavaScript, Go y Python
- Puede ser un **trabajo remunerado**



Splunkbase (Apps)

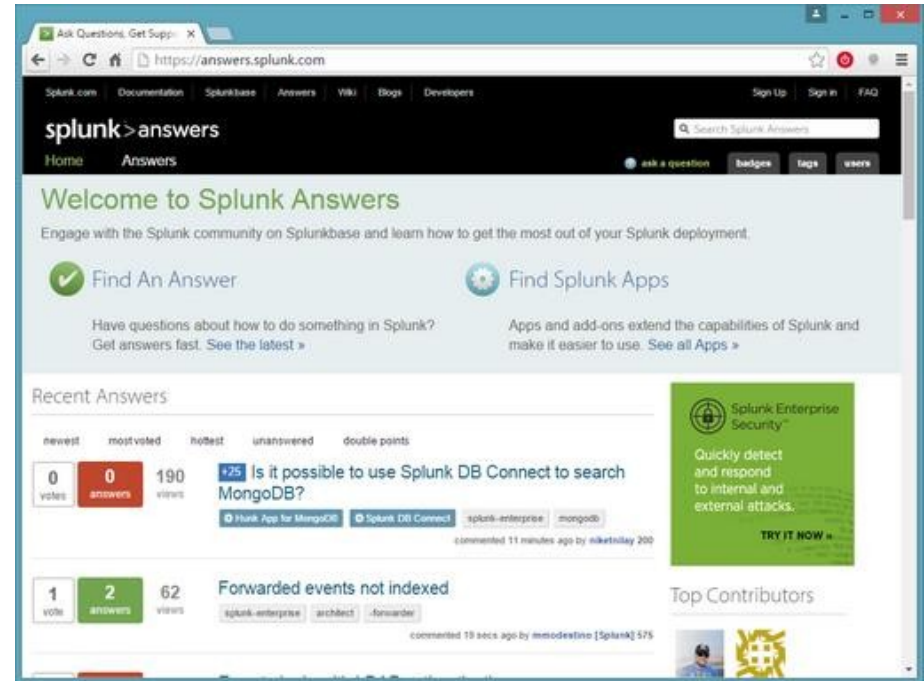
- Las Apps permiten ampliar la funcionalidad de Splunk de forma prácticamente ilimitada



Splunk answers

- Ayuda técnica
- Gestionada por la comunidad
- Soportada por splunk
- Intercambio de conocimiento
- Q&A

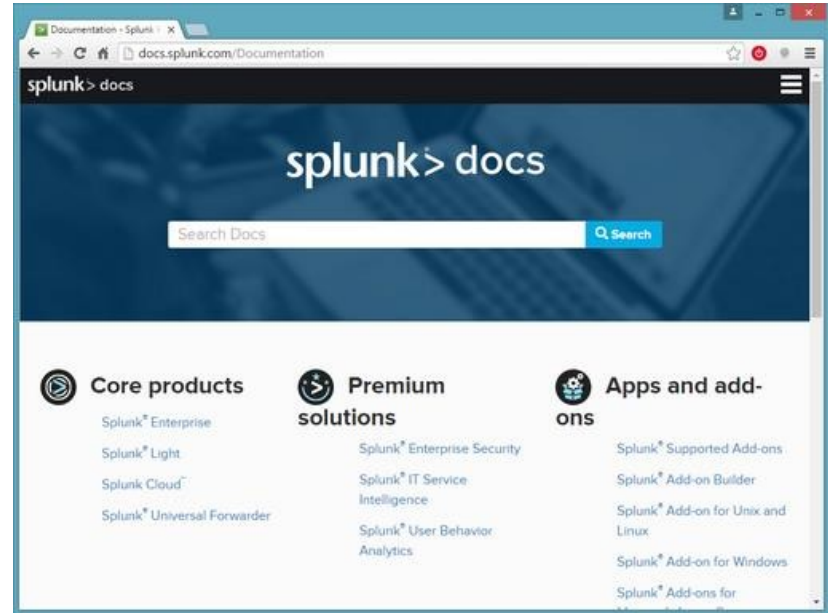
<https://answers.splunk.com>



Splunk Documentation

- Ayuda técnica
- Documentación oficial
- Wiki y community
- Actualizada diariamente
- Disponible en PDF

<https://docs.splunk.com/>



Getting started

- Tutoriales de búsqueda
- Fundamentos
- Flexible para cualquier necesidad
 - Incorporación de datos
 - Reenvío de datos
 - Búsqueda y dashboards
 - Informes y alertas
- Casos de uso

Getting Data In

Getting Data In — Windows (4:07)



Install a Windows universal forwarder from an installer (docs)

Getting Data In — Linux (4:47)



Install a *nix universal forwarder (docs)

Getting Data In — Forwarders (4:34)



Download a universal forwarder
How to forward data to Splunk Enterprise (docs)

Enterprise | Cloud



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Splunk Bots (Boss of the SOC)

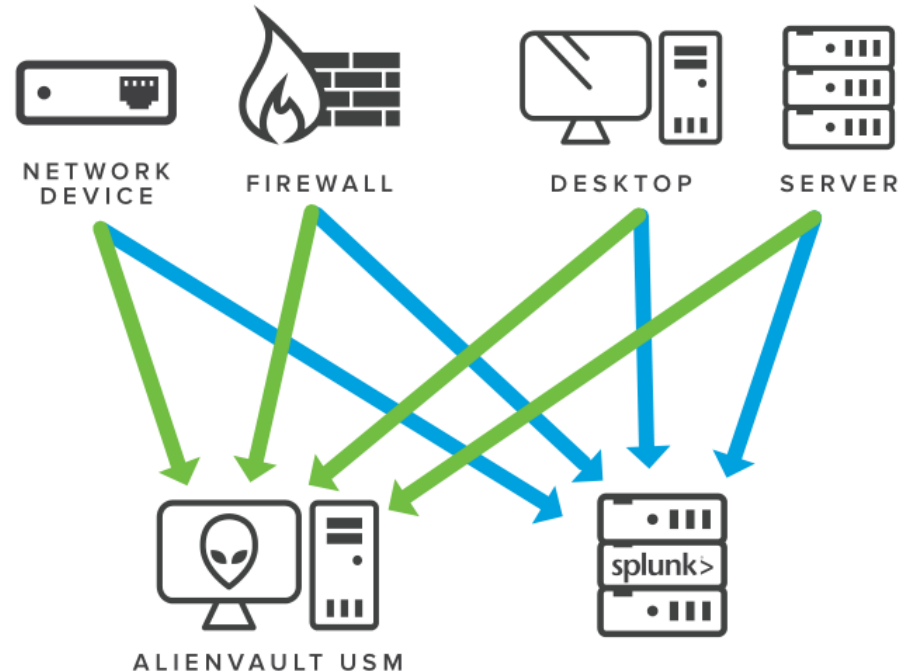


- Actividad de tipo CTF ([Capture the Flag](#))
 - Orientada a los "equipo azules" (4-5h; 1-4 personas)
 - Preguntas sobre incidentes de seguridad reales en un entorno empresarial realístico pero ficticio
 - Se utiliza Splunk para buscar pero no todas las preguntas se pueden contestar sin utilizar otros recursos OSINT
- Recursos:
 - [Hunting with Splunk: The Basics](#)
 - [Boss of the SOC v1 Dataset](#)
 - [Boss of the SOC v2 Dataset](#)
 - [Boss of the SOC v3 Dataset](#)
 - [Threat Hunting with Splunk](#)
 - [Advanced Incident Detection and Threat Hunting using Sysmon \(and Splunk\)](#)



OSSIM + Splunk

- OSSIM
 - Inteligencia de amenazas
 - Controles de seguridad integrados:
 - Activos
 - Vulnerabilidades
 - Amenazas
 - Correlación de datos
 - ~2000 directivas
- Splunk
 - Recopilación de datos
 - Almacenamiento de datos a largo plazo
 - Análisis de Big Data



Introducción a Splunk



- Configuración inicial
- Datos locales
- Datos remotos (forwarders y syslog)
- Búsquedas

Splunk (Opcionales)



- Investigar, en grupo o individualmente, las posibilidades que ofrecen OSSIM y Splunk e intentar usarlos para resolver ejercicios de módulos anteriores
- Realizar los ejercicios básicos del Splunk Search Tutorial para conocer el lenguaje SPL (Search Processing Language)